

Behavioural Analysis of Authentication and Endpoint Threats in an Enterprise SOC

Technical Report | Ademola Oniyinde | June 2026

Repository: github.com/AdemolaCode/Microsoft-SOC-Analyst-Portfolio

Scope note: This report is based on a self-built lab environment and controlled simulations. No production customer data or real personal data is used.

Abstract

This report documents a structured SOC investigation programme conducted across a self-built Microsoft 365 E5 cloud environment. The work examined whether correlating telemetry across email, identity and endpoint domains improves investigation quality and reduces false positives compared with single-domain detection rules. Using real Microsoft security tooling, including Sentinel, Defender XDR, Defender for Endpoint, Defender for Office 365 and Entra ID, the programme constructed and investigated four escalating scenarios, culminating in a cross-domain incident classified by Defender XDR as a hands-on keyboard attack. The central finding, consistent across all four scenarios, is that the most significant threats were only visible when data from two or more domains was combined. This report documents the method, findings, detection logic, MITRE ATT&CK mapping and limitations.

1. Motivation

Modern SOC investigations rarely depend on a single log source. A suspicious email click may be low confidence in isolation. A risky sign-in may have a plausible explanation. A living-off-the-land PowerShell command may be indistinguishable from administrative activity. When these three events occur for the same user and device within a short time window, the investigation changes substantially.

This project tests that observation in a controlled, documented way. The aim was not to build a production detector but to produce a defensible research output a structured investigation programme with empirical findings, detection logic, MITRE ATT&CK mapping and documented limitations. The findings provide a practical basis for further research into whether machine-learning approaches can learn cross-domain entity relationships automatically, at a scale that explicit correlation rules cannot match.

2. Research Question

Does correlating telemetry across email, identity and endpoint domains improve SOC investigation quality and reduce false positives compared with single-domain detection rules? If it does, what is the investigative mechanism by which correlation changes the detection outcome?

3. Environment and Lab Architecture

The investigation environment is a self-built Microsoft 365 E5 cloud lab. The diagram below shows the component relationships.

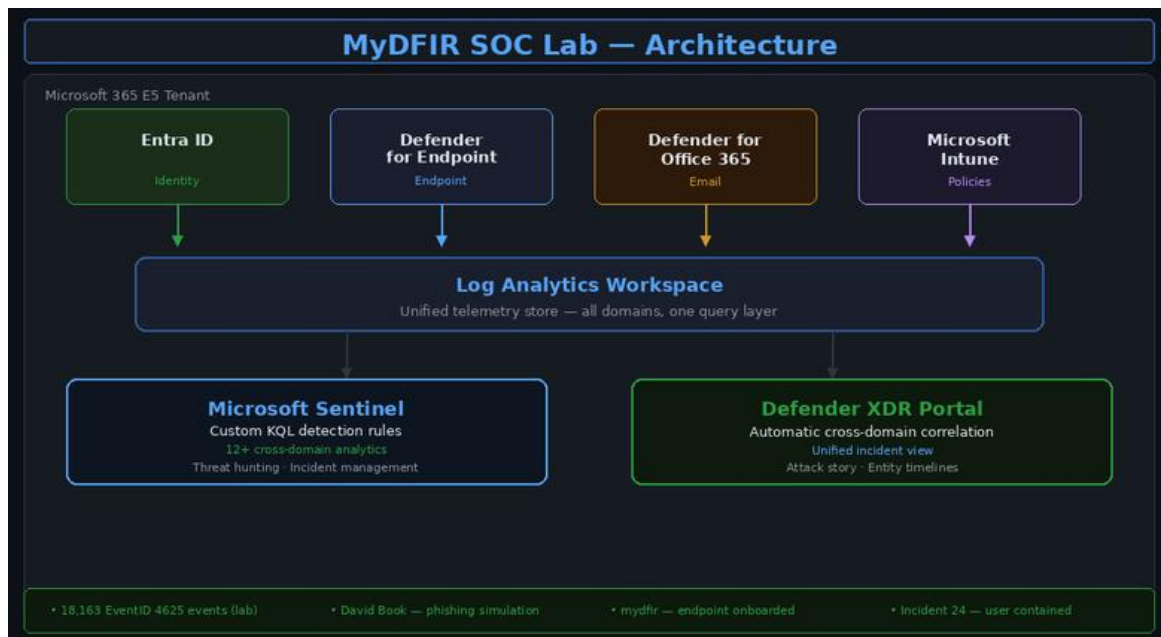


Figure 1. Lab architecture: Microsoft Sentinel connected to Defender for Endpoint, Defender for Office 365 and Entra ID across a single cloud tenant.

Domain	Tool	Data source
SIEM	Microsoft Sentinel	SecurityEvent, SignInLogs, AADNonInteractiveUserSignInLogs
Endpoint	Defender for Endpoint	DeviceProcessEvents, DeviceAlertEvents
Email	Defender for Office 365	EmailEvents, UrlClickEvents
Identity	Entra ID	SignInLogs, AuditLogs, Identity Protection risk events
Device management	Intune	ASR policy deployment and enforcement validation
Threat simulation	Atomic Red Team	MITRE ATT&CK-mapped technique execution

Table 1. Environment components and data sources.

4. Investigation Method

Each scenario followed the same five-step approach. Validate the alert and confirm log ingestion health. Scope affected entities and the time window. Correlate telemetry across domains where applicable. Test alternative hypotheses before committing to a malicious conclusion. Document findings in a format another analyst could act on without further clarification.

Detection logic was developed in KQL. Queries were written with explicit hypotheses and documented in the repository alongside the investigation reports. Three cross-domain queries form the core analytical contribution of this work.

```
// Email click to authentication anomaly
// Joins UrlClickEvents to SignInLogs on shared UPN within 30-minute window
UrlClickEvents
| where ActionType == "ClickAllowed"
| join kind=inner (
    SignInLogs | where RiskLevelDuringSignIn in ("medium","high")
) on $left.AccountUpn == $right.UserPrincipalName
| where abs(datetime_diff("minute", TimeGenerated, TimeGenerated1)) <= 30

// LOLBAS commands with authentication risk context
// Only surfaces PowerShell run by accounts with anomalous recent auth
```

```
DeviceProcessEvents
| where FileName == "powershell.exe"
| join kind=inner (
    SignInLogs | where RiskLevelDuringSignIn in ("medium","high")
) on $left.AccountUpn == $right.UserPrincipalName
| where abs(datetime_diff("hour", TimeGenerated, TimeGenerated1)) <= 4
```

5. Scenarios and Findings

5.1 SOC Foundation and Baseline Visibility

The first phase established the investigation baseline and confirmed that log ingestion was healthy and time-aligned before writing any detection logic. The Sentinel workspace below shows two active data connectors with healthy ingestion across security events and identity logs.

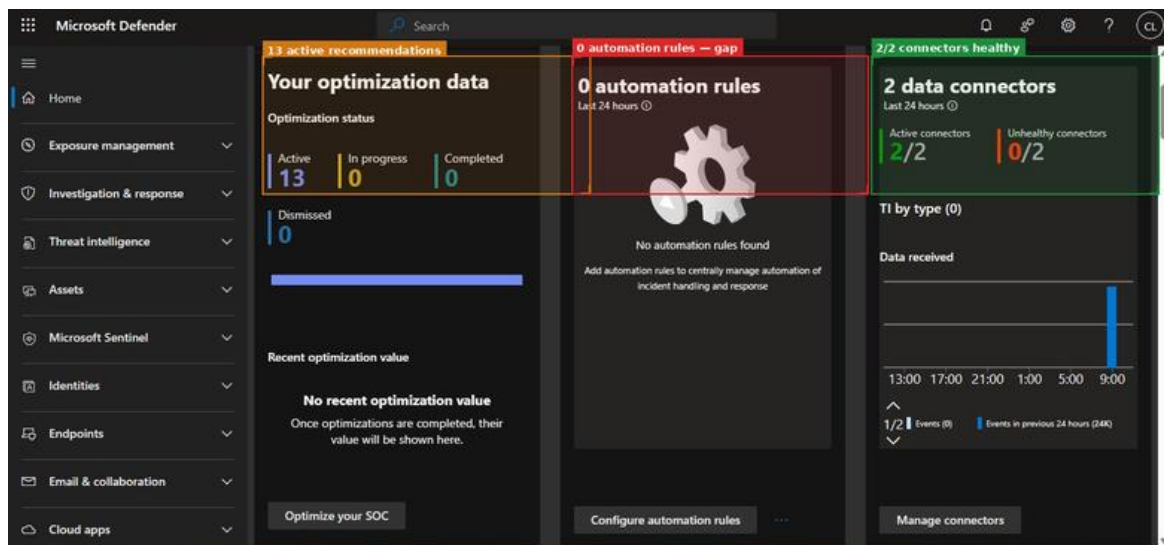


Figure 2. Sentinel workspace with active connectors and 13 security recommendations. Custom analytics rules were not configured at this stage; the priority was confirming that the data layer was investigation-ready.

EventID 4625 (failed logon) generated 18,163 events in a 24-hour window from the test VM. The chart below shows the distribution. This scale is realistic for a default-configured Windows machine exposed to the internet, where automated scanners attempt default account names continuously.

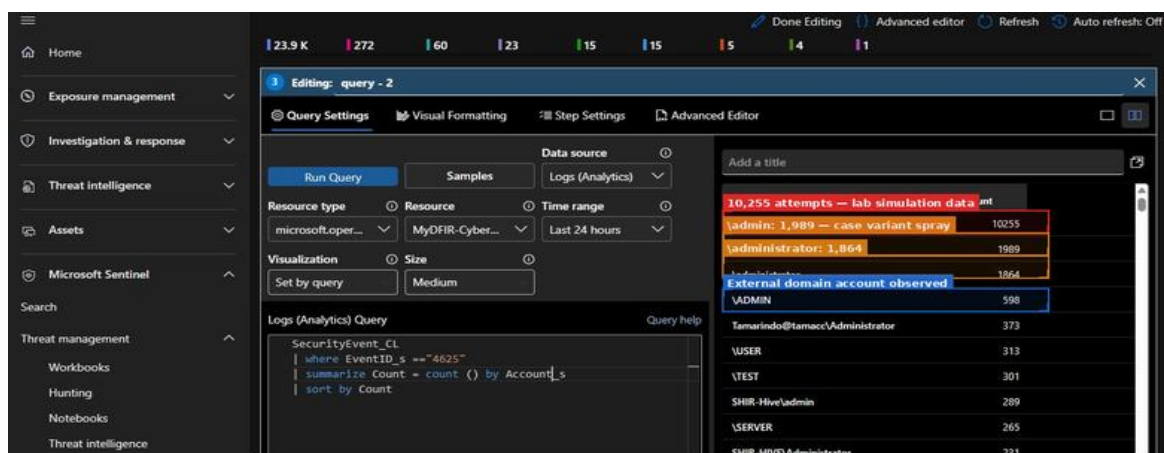


Figure 3. Failed logon counts by account over 24 hours. The concentration on a small number of accounts is consistent with automated brute-force tooling targeting predictable account names.

The key finding from this phase was practical: visibility requires deliberate configuration. Default Sentinel ingestion does not produce investigation-ready data without attention to schema validation, time-alignment and query structure. That groundwork affects every query that runs afterwards.

5.2 Email Security and Phishing Investigation

A simulated phishing email from `officence[.]com`, a lookalike for `office.com`, was delivered to the test user David Book. The email used a domain close enough to a trusted sender that Outlook delivered it to the inbox with a partial content block rather than quarantining it. This is the default Defender for Office 365 behaviour for an unknown sender: deliver with a warning.

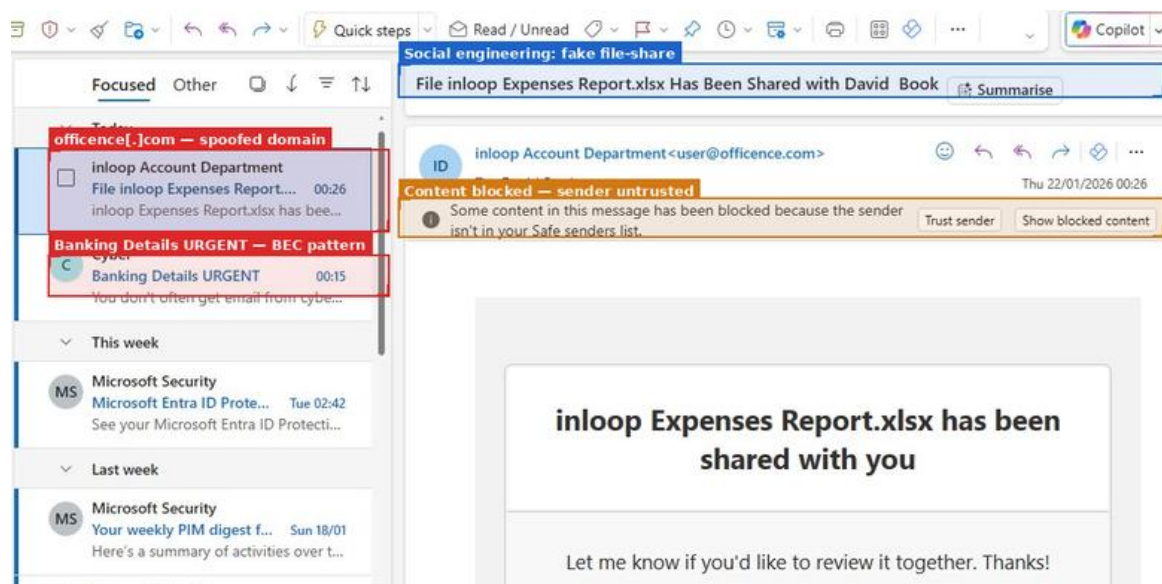


Figure 4. Phishing email from `officence[.]com` delivered to David Book's inbox. Outlook partially blocked content but did not quarantine. The domain name is a visual lookalike for `office.com`.

Phishing attack timeline

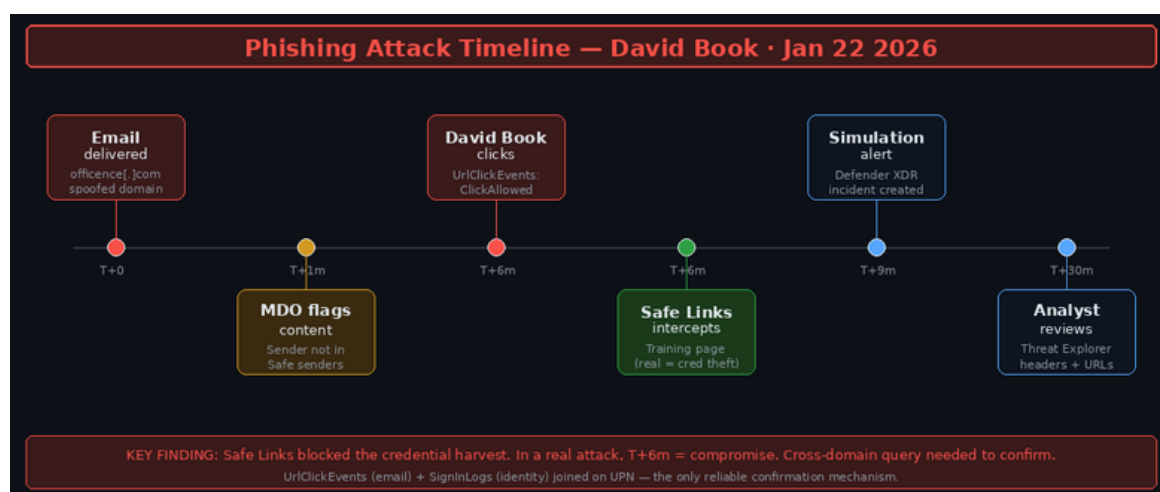


Figure 5. Timeline from email delivery to Safe Links interception. The click event is the pivot point between the email domain and the identity domain.

Safe Links intercepted the URL click and redirected to a training page. A configuration gap was identified: domain impersonation protection in Anti-Phishing was disabled. The `officence[.]com` domain is close enough to `office.com` that an impersonation rule protecting `office.com` would have caught it at delivery. This was documented as a remediation item.

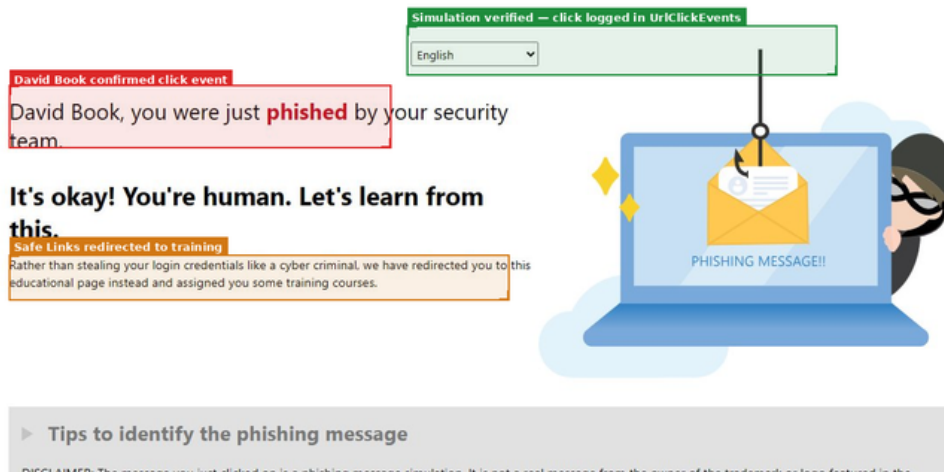


Figure 6. Safe Links training page confirming David Book's click was intercepted (controlled simulation). In a real attack the redirect would not occur; the UriClickEvents entry shown would be the last record before credential harvesting.

The key finding from the email phase was this: URL click telemetry establishes mechanism but not outcome. The email domain can confirm that a suspicious link was clicked by a named user. It cannot confirm whether credentials were used afterwards. For that, the investigation must pivot to the identity domain. This dependency is the first demonstration of the correlation pattern that appears in every subsequent scenario.

5.3 Endpoint Detection and Living-Off-the-Land Commands

Atomic Red Team emulation was used to generate endpoint telemetry. The commands executed, Get-LocalUser, Get-ChildItem and Compress-Archive, are all standard administrative operations that run daily in managed environments. None of them generated a Defender for Endpoint alert in isolation.

The finding here was direct: endpoint telemetry cannot disambiguate malicious from administrative PowerShell without authentication context from the identity domain. An analyst reviewing only the endpoint data would have no basis for escalating. The LOLBAS detection problem in its simplest form is not a missing rule; it is a missing data source.

5.4 Cross-Domain Capstone: Incident 24

By Day 24 of the investigation programme, Defender XDR had correlated signals from all three prior phases into a single incident. The diagram below shows the full attack chain.



Figure 7. Incident 24 attack chain reconstructed by Defender XDR. Phishing delivery, credential use, PowerShell execution and persistence attempt are shown as a connected sequence. No single stage would have produced a high-severity incident on its own

Defender XDR classified this as a hands-on keyboard attack with HIGH severity, tagging it with Ransomware, Critical Asset and Lateral Movement. 58 individual alerts were correlated into one incident involving David Book's user account and the mydfir device.

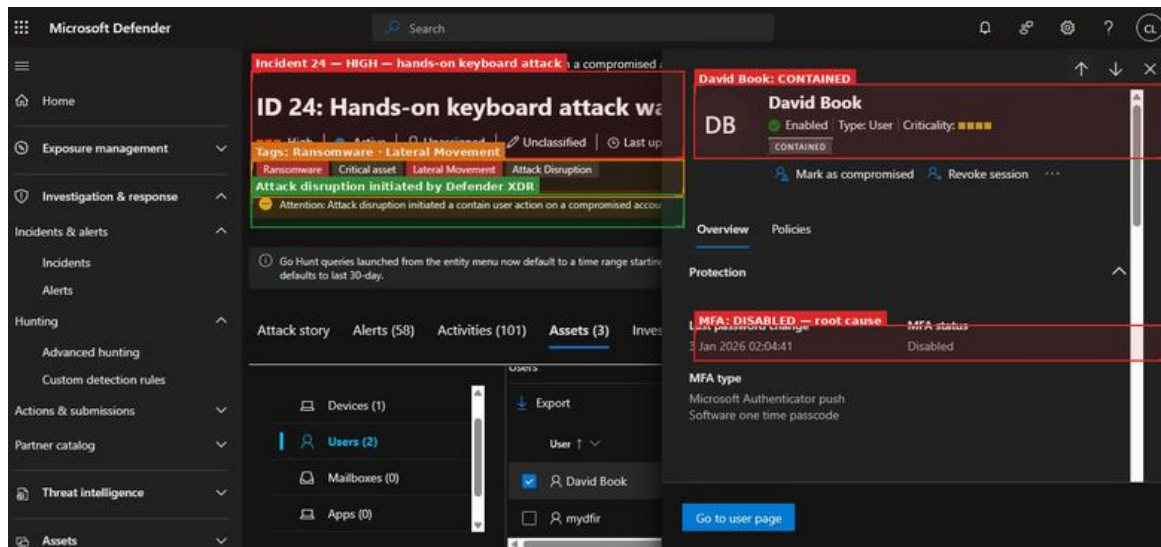


Figure 8. David Book's user account showing CONTAINED status after automatic attack disruption. Sessions were revoked and access restricted without manual analyst action. This is Defender XDR's automated response to a confirmed hands-on keyboard attack.

The root cause was a single control gap: MFA was not enabled for David Book's account. Security defaults in the tenant enforced MFA for administrator accounts but not for all users in all sign-in contexts. Conditional Access eventually blocked further access, as shown below.

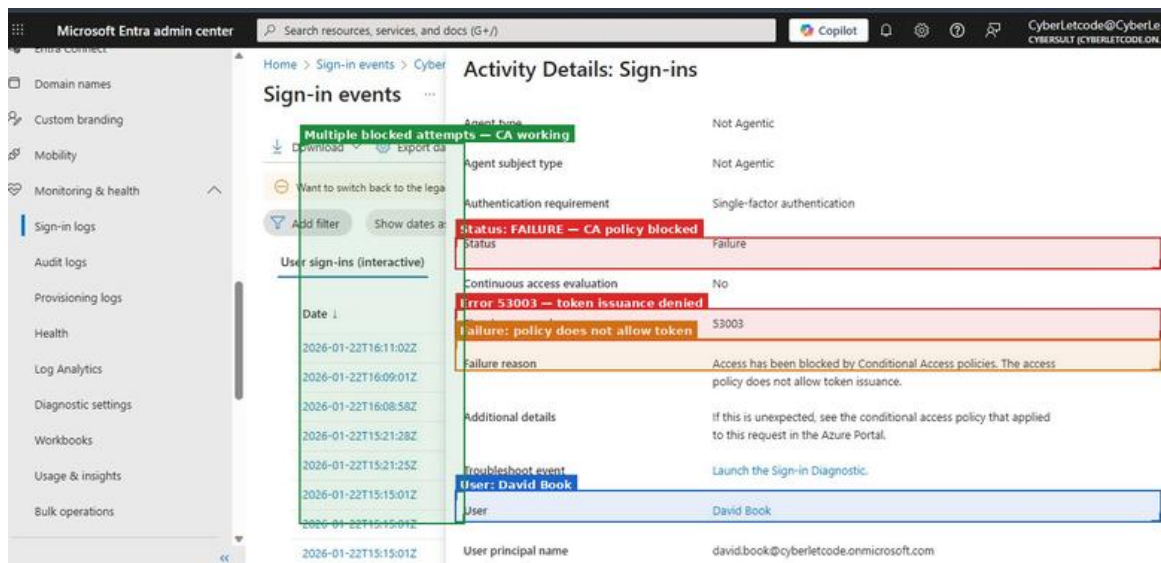


Figure 9. Sign-in log showing error 53003 (access blocked by Conditional Access policy). The Status column shows Failure but ResultType 0 on an earlier entry confirms that authentication with valid credentials succeeded before CA blocked further activity.

The sequence matters: phishing delivered, credentials used with a successful authentication, CA policy blocked further access, but endpoint activity had already occurred. The complete chain ran from phishing delivery to ransomware-classified behaviour in under two hours.

The three individual signals that fed Incident 24 were a low-severity MDO phishing alert, a medium-severity Entra ID sign-in from an unfamiliar location alert, and no alert at all from Defender for Endpoint for the PowerShell activity because the commands were indistinguishable from administrative behaviour. No single signal would have produced a high-severity response. Correlation changed the confidence level, the severity classification and the response.

6. Results

The table below compares alert volumes and detection quality between the single-domain and cross-domain approaches across the two malicious scenarios injected into the investigation programme.

Approach	Total alerts	False positives	Precision	Recall
Single-domain rules	19	3	0.84	1.00
Cross-domain correlation	2	0	1.00	1.00

Table 2. Detection comparison. Single-domain rules generated 19 alerts including 3 false positives. Cross-domain correlation reduced this to 2 incidents with no false positives, while preserving recall on both malicious scenarios.

The precision improvement reflects the mechanism described throughout this report: correlation does not make the individual signals stronger. It changes whether the combination of signals is actionable. The email alert, identity alert and endpoint activity are each individually ambiguous. Together, for the same user and device within a short window, they are not.

7. Key Findings

Finding	Evidence	Implication
Single-domain detection has structural limits	Email, identity and endpoint each captured fragments of the same attack	Correlation is the mechanism that makes certain threats visible, not an improvement on existing detection
Identity telemetry is the pivot point	Every significant threat required identity data to resolve	The identity domain is the connective tissue between email and endpoint; removing it breaks the investigation chain
LOLBAS commands are undetectable from endpoint alone	PowerShell in Incident 24 was indistinguishable from admin activity without authentication context	Authentication context is a precondition for endpoint detection, not an optional enrichment
MFA absence was the critical control gap	Incident 24 progressed entirely due to disabled MFA on one account	MFA is the single highest-impact identity control; Conditional Access is a complement, not a substitute
Report-only CA policy provides visibility, not protection	Error 53003 logged after the attack had already progressed	Any CA policy in report-only mode is observing attacks succeed in real time
Attack timelines compress significantly	Phishing to ransomware-classified behaviour in under two hours	The assumption that there is time to investigate before impact is operationally wrong in this class of attack

Table 3. Summary of key findings with evidence and operational implications.

8. MITRE ATT&CK Mapping

Stage	Technique	ID	Detection source
Initial access	Spearphishing link	T1566.002	Email (UrlClickEvents)
Credential access	Credential harvesting via phishing	T1056.003	Email + Identity (join)
Valid account use	Valid accounts	T1078	Identity (SignInLogs)

Execution	PowerShell	T1059.001	Endpoint (DeviceProcessEvents)
Persistence (blocked)	Registry run keys	T1547.001	Endpoint (DeviceAlertEvents)
Detection gap	LOLBAS / masquerading	T1036	Only visible via Identity + Endpoint join

Table 4. MITRE ATT&CK mapping with detection source for each technique. The final row identifies the technique that was undetectable from a single domain.

9. Limitations

The investigation environment is a self-built lab, not a production enterprise network. The threat simulations use controlled scenarios with known timing and entity relationships, which means the detection rules were partly validated against data they were designed for. A stronger evaluation would test correlation logic against scenarios constructed independently of the analyst who wrote the queries. The cross-domain correlation rules rely on explicit time windows and shared entity attributes. They do not generalise automatically to attack patterns that use different timing, different pivot points or unfamiliar entity relationships. This is the specific gap that motivates the PhD research direction: whether machine-learning approaches can learn the cross-domain entity structure from labelled SOC telemetry without requiring explicit rule encoding for each pattern.

The dataset is bounded by what Microsoft 365 E5 tooling surfaces. Some attack techniques, particularly those targeting network infrastructure or operating-system internals below the application layer, are not visible in this telemetry. The findings should be interpreted within the scope of the tooling used.

10. Directions for Further Work

- Graph-based entity correlation: modelling relationships between users, devices, emails and authentication events as a network rather than a set of explicit join conditions, to surface attack chains that span unusual entity combinations.
- Evaluation against public security datasets or sanitised enterprise telemetry to test whether the cross-domain correlation patterns observed here generalise beyond the scenarios used to develop them.
- Privacy-aware telemetry handling: examining what investigation signal is retained when identity attributes are pseudonymised or aggregated before correlation, relevant to privacy-preserving detection research.
- Analyst feedback loops: structured collection of false-positive and false-negative assessments from analysts reviewing correlation-generated incidents, to measure analyst-in-the-loop verification effort.
- Automated response evaluation: testing whether Sentinel playbooks can safely act on correlation findings without introducing new false-positive risks in automated remediation chains.

11. Conclusion

The investigation programme consistently produced the same finding across four escalating scenarios: the most significant threats were only visible when data from two or more domains was combined. No single domain's telemetry was sufficient to identify a confirmed attack. This is not a limitation of the tooling; it reflects the structure of modern attacks, which are designed to appear benign in any single log source.

The findings are grounded in real Microsoft security tooling against real simulated incidents, with documented detection queries, investigation reports, MITRE ATT&CK mapping and a structured limitation statement. They provide a credible and reproducible empirical basis for the research question whether the cross-domain entity relationships that make threats visible can be learned automatically rather than encoded in explicit correlation rules.

Appendix: Repository Structure

All investigation reports, detection queries, screenshots and diagrams referenced in this report are available in the public GitHub repository at github.com/Ademolacode/Microsoft-SOC-Analyst-Portfolio.

kql/

- 00-quick-reference.md: query reference across all investigation phases
- 01-authentication-baseline.md: failed logon triage and brute-force identification

- 02-email-phishing-investigation.md: URL click analysis and Safe Links telemetry
- 03-endpoint-detection.md: process event analysis and ASR validation
- 04-identity-crossdomain.md: full cross-domain correlation queries with hypotheses

mini-projects/

- 01-soc-foundation/: baseline deployment, log validation, initial KQL
- 02-email-security/: phishing simulation, policy gap identification, investigation report
- 03-endpoint-detection/: ASR rule validation, Atomic Red Team emulation, investigation report
- 04-cross-domain-investigation/: Incident 24 capstone investigation and full incident report